

Malware Threat Investigation: CryptoLocker Ransomware

Author: Weilong Xu (Edison)

Executive Summary

Incident Overview

- After investigating all the provided artifacts relating to the execution of suspected.exe, it is confirmed that the malware is ransomware with additional keylogging capabilities. The malware appears to be CryptoLocker.

Business Impact Analysis

- The ransomware will lock all files on the victim's computer, especially important personal and business-related files. The encryption method appears to be RSA/AES, which requires a key to unlock. The program will display a message on the screen asking for payment in exchange for the unlock key. Additionally, since there are keylogging capabilities, all information typed during the ransomware infection will be exposed and recorded.

Current Threat Status

- The ransomware has already been activated and has added an auto startup file in the registry. There is also an HTTP connection, which may indicate that the attacker is receiving data (currently unsure whether it's keystrokes or the encrypted files). What we can do now is disconnect from the internet and prevent it from spreading, as it may contain additional threats.

Technical Analysis

- In regshot-x64, I found a suspicious name called CryptoLocker, which sounds like a malware name for ransomware.

```
soft\Windows\CurrentVersion\Explorer\UserAssist\{CEBFF5CD-ACE2-4F4F-9178-9926F41749EA}\Count\P:\Hfref\uxqf\Qrfxgbc\q765r722r295969p0n5p2q90
soft\Windows\CurrentVersion\Run\CryptoLocker: "C:\Users\hkds\AppData\Roaming\{213D7E33-3912-1C20-3D05-020A14CDFFF3}.exe"
soft\Windows NT\CurrentVersion\AppCompatFlags\Compatibility Assistant\Store\C:\Users\hkds\Desktop\d765e722e295969c0a5c2d90f549db8b89ab61790
```

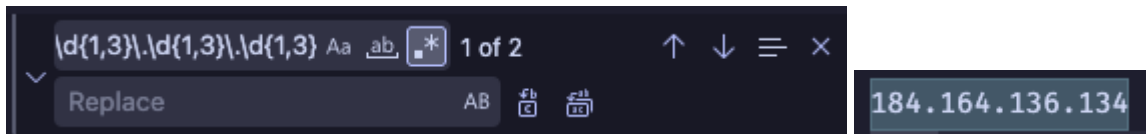
- The path of the file is
C:\Users\hkds\AppData\Roaming\{213D7E33-3912-1C20-3D05-020A14CDFFF3}.exe
- Since this program has been added to the registry, it will run every time the computer starts.

```
CryptoLocker
Attention!
Error
Unknown error occurred.
Please try again later, or restart your computer.
View files
Open %s
Open in Bitcoin client
Copy Bitcoin address
Copy
Select all
Private key will be destroyed on
Time left
%u : %02u : %02u
Your personal files are encrypted!
Next >>
Payment for private key
<< Back
PAY
Choose a convenient payment method:
MoneyPak (USA only)
Enter the card number and press
Pay
Ukash
Enter the code of the card, select card currency, and press
Pay
cashU
Enter the coupon code and click
Pay
Bitcoin (most cheap option)
Enter the transaction ID and press
Pay
Payment method: %s
Code: %s
Amount: %s
Make sure that you enter the payment information correctly! Each incorrect attempt will reduce the time to destroy the private key in h
Are you sure you entered your payment information correctly?
You entered the wrong payment information.
You entered the wrong payment information.
Time until the private key destruction is reduced.
Waiting for payment activation
Payments are processed manually, therefore, the expectation of activation may take up to 48 hours.
The private key destruction is suspended for the time of payment processing.
```

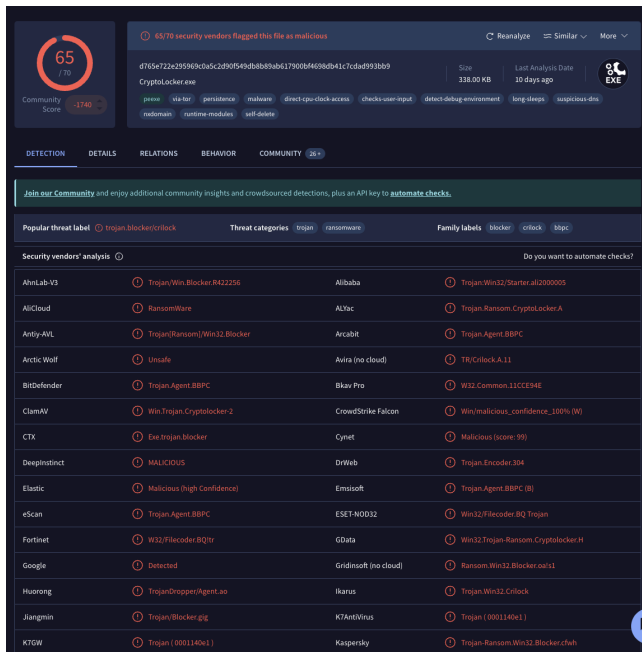
- By searching the name in the strings file, I found direct evidence of the ransomware with the prompt being raw text instead of encrypted.
- The result: It is confirmed that the suspicious file is an auto startup ransomware.
- As how ransomware usually work, I begin to find if there is any connection between the hacker and the file, such as file transfer or other potential threat

```
POST
GET
HTTP/1.1
```

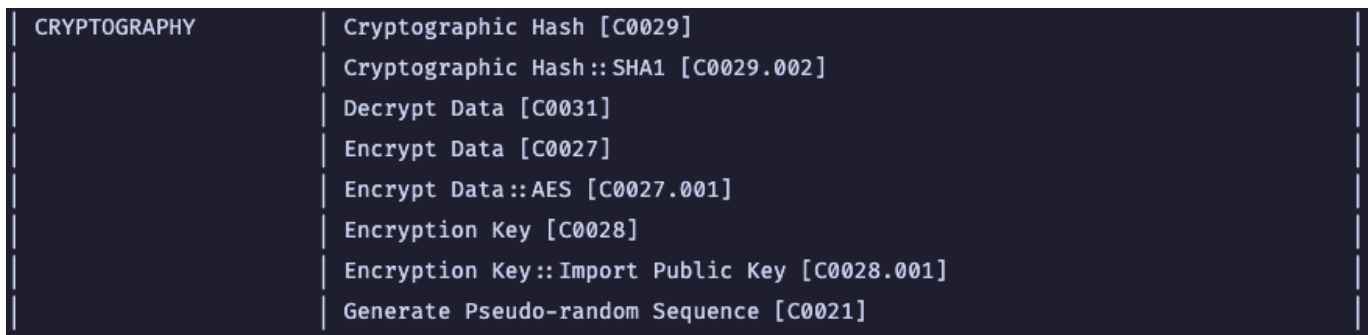
- And here I found a potential internet connection via HTTP, there must be an ip address that the hacker uses to talk with the victim's computer.



- Inside the strings.txt file, using some expressions, I found an ip which seems to be the hacker's ip.



- I also found the hash for the exe in the capa.txt file, which I tried searching in VirusTotal. This is the result. (Doing this to confirm what I have found so far)



- In the capa file, I also found some cryptography method which seems to be how the hacker encrypts the victim's file and how it may be transferred to the hacker remotely.

ATT&CK Tactic	ATT&CK Technique
COLLECTION	Clipboard Data [T1115] Input Capture::Keylogging [T1056.001]
DEFENSE EVASION	File and Directory Permissions Modification [T1222] Hide Artifacts::Hidden Window [T1564.003] Modify Registry [T1112]
DISCOVERY	Obfuscated Files or Information [T1027] File and Directory Discovery [T1083] Query Registry [T1012] System Information Discovery [T1082] System Location Discovery::System Language Discovery [T1614.001]
EXECUTION	Command and Scripting Interpreter [T1059] Shared Modules [T1129]
PERSISTENCE	Boot or Logon Autostart Execution::Registry Run Keys / Startup Folder [T1547.001]

- Based on the attack tactic in the capa file, it also appears that the hacker uses keylogging method which may also indicate that not only the victim's files are encrypted, there is a high possibility that the hacker will record all the victim's key strokes when the victim types their information method while transferring the payment.
- This means the hacker is looking forward to more than what was asked during the ransome phase.

IOC Table

md5	04fb36199787f2e3e2135611a38321eb
sha1	65559245709fe98052eb284577f1fd61c01ad20d
sha256	d765e722e295969c0a5c2d90f549db8b89ab617900bf4698db41c7cdad993bb9
analysis	static
os	windows
format	pe
arch	i386
path	C:/Users/hkds/Desktop/suspected.exe

- I found this table in the capa txt file which I believe can be used as the IOC Table, but just making sure that we cover everything, we will also add the ip address of the hacker.
- As well as some of the registry paths.

Name	Information
md5	04fb36199787f2e3e2135611a38321eb
sha1	65559245709fe98052eb284577f1fd61c01ad20d
sha256	d765e722e295969c0a5c2d90f549db8b89ab617900bf4698db41c7cdad993bb9
Malware Name	CryptoLocker
Malware Type	Ransomware
Auto Startup registry Key	HKU\S-1-5-21-2649495649-2222007532-926028777-1000\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\CryptoLocker
Generated Auto Startup File	C:\Users\hkds\AppData\Roaming\{213D7E33-3912-1C20-3D05-020A14CDFF F3}.exe
Hacker's IP	184.164.136.134

Defense Recommendations

1. Unplug the Computer immediately since I found an IP address (184.164.136.134) that the malware uses to talk to the hacker.
2. To stop the malware from running any further, we need to open Task Manager and kill the process.
3. We should also try to remove the registry to avoid the malware from auto startup.
4. We should not pay the hacker, as we are not certain whether or not we will receive a key and the fact that the keylogging will record our information.
5. Block the Hacker's IP that we found immediately for the victim's computer and any other computers that are connected to the same internet.